

Web Application Security API Testing of KMS WebServices

Test URL:

<https://compaudit.eoffice.gov.in/KMS/kmsApiUserPermissionService.json>

<https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json>

<https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json>

<https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json>

<https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json>

<https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json>

Level-1 Report

07 February, 2025



AAA Technologies Ltd

278-280, F Wing, Solaris-1,
Saki Vihar Road, Opp. L & T Gate No. 7,
Powai, Andheri (East),



API Security Test Report

Presented by:

Pranav Singh

Application Testing Conducted On:

06-02-2025 to 07-02-2025

API Security Test Report For KMS Web Services



Table of Contents

1. No Rate Limit.....	5
2. Parameter Validation Is Missing	6
3. Cross-Origin Resource Sharing Misconfiguration	7
4. CSRF Token Not Validated	8
5. HTTP Security Header Not Implemented.....	<u>10</u>
6. Session Cookie without Secure Flag	11

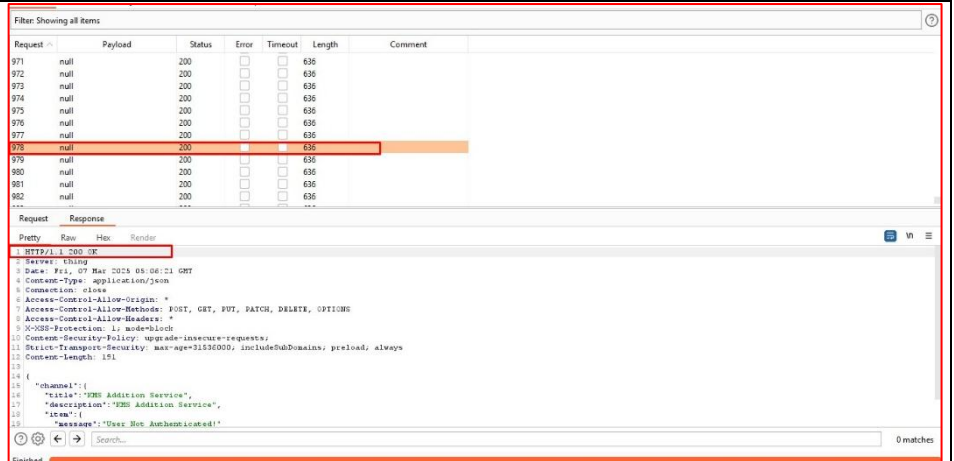


Medium

API Security Test Report For KMS Web Services



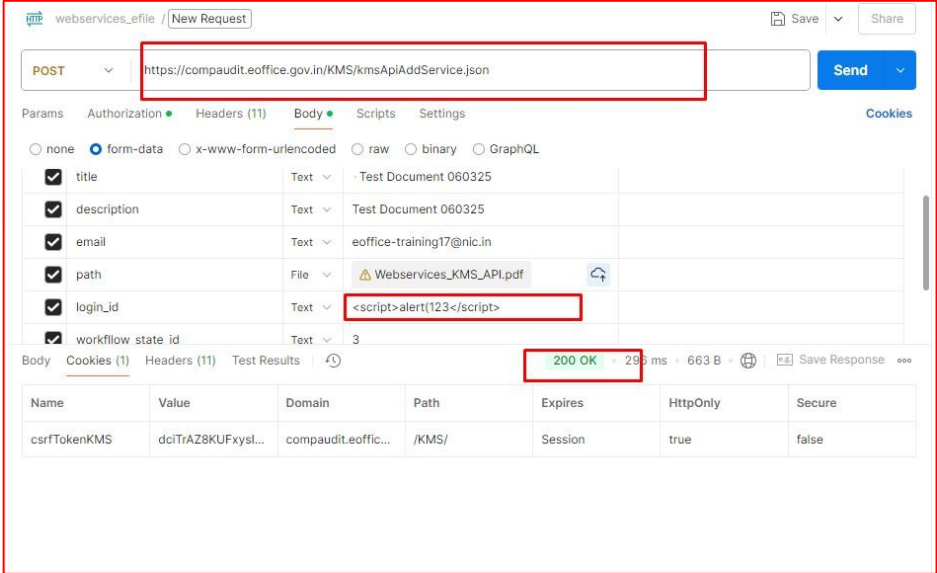
1. No Rate Limit

Vulnerability Title: No rate limit	
Risk	Medium
Abstract	The application does not enforce rate limiting on incoming requests, allowing attackers to send a high volume of automated requests. This can lead to resource exhaustion, degraded performance, or service unavailability.
Ease of Exploitation	Easy
Impact	Excessive server resource consumption, causing degraded performance or Denial of Service (DoS) Potential exposure of sensitive or confidential information through mass downloads
Recommendations	It is recommended that implement rate limit
Snapshot	
Affected URLs	https://compaudit.eoffice.gov.in/KMS/kmsApiUserService.json https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json

API Security Test Report For KMS Web Services



2. Parameter Validation Is Missing

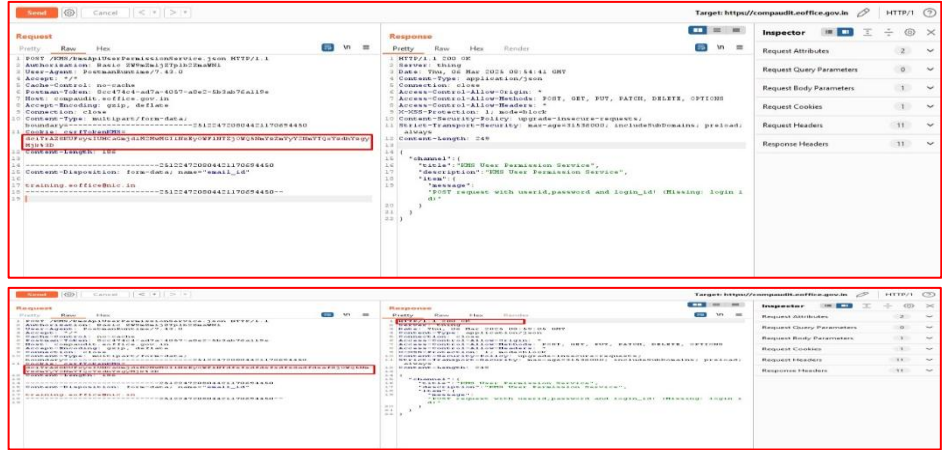
Vulnerability Title: Parameter Validation is Missing	
Risk	Medium
Abstract	It was observed that the parameter validation is missing on some parameters. i.e.,script tags are allowed,null validation allowed
Ease of Exploitation	Easy
Impact	It may lead to parameter tampering, XSS like attack.
Recommendations	It is recommended to implement proper input validation at both client and server side at each and every parameter.
Snapshot	
Affected Site	https://compaudit.eoffice.gov.in/KMS/kmsApiUserPermissionService.json https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json

Vulnerability Title: Cross origin resource sharing misconfiguration	
Risk	Medium
Abstract	It was observed that the CORS Cross Origin Resource Sharing Misconfiguration Lead to sensitive information.
Ease of Exploitation	Hard
Impact	Attacker would treat many victims to visit attacker's website, if victim is logged in, then his personal information is recorded in attacker's server.
Recommendations	It is recommended to rather than using a wildcard or programmatically verifying supplied origins, use a whitelist of trusted domains.
Snapshot	
Affected Site	https://compaudit.eoffice.gov.in/KMS/kmsApiUserPermissionService.json https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json

API Security Test Report For KMS Web Services



4. CSRF Token Not Validated

Vulnerability Title: CSRF Token Not Validated	
Risk	Medium
Abstract	The application does not validate CSRF tokens, making it vulnerable to Cross-Site Request Forgery (CSRF) attacks. Attackers can trick authenticated users into unknowingly executing unwanted actions on the site.
Ease of Exploitation	Easy
Impact	Attackers can perform unauthorized actions on behalf of authenticated users, such as changing account settings, making transactions, or deleting data.
Recommendations	Implement and enforce CSRF token validation for all state-changing requests. Use secure, unique, and per-session CSRF tokens. Ensure CSRF tokens are validated server-side. Consider using the Same Site cookie attribute to prevent CSRF attacks
Snapshot	
Affected Site	https://compaudit.eoffice.gov.in/KMS/kmsApiUserPermissionService.json https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json



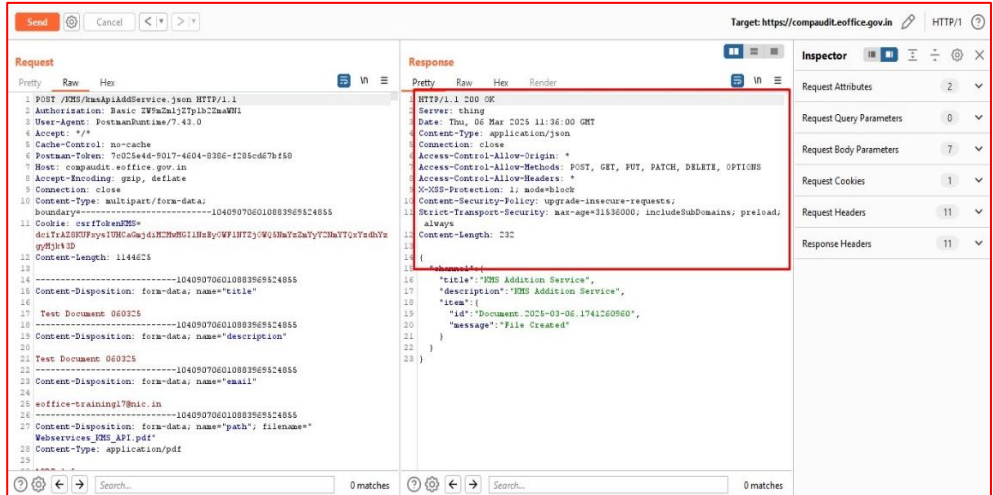
LOW

API Security Test Report For KMS Web Services



5. HTTP Security Headers Not Implement

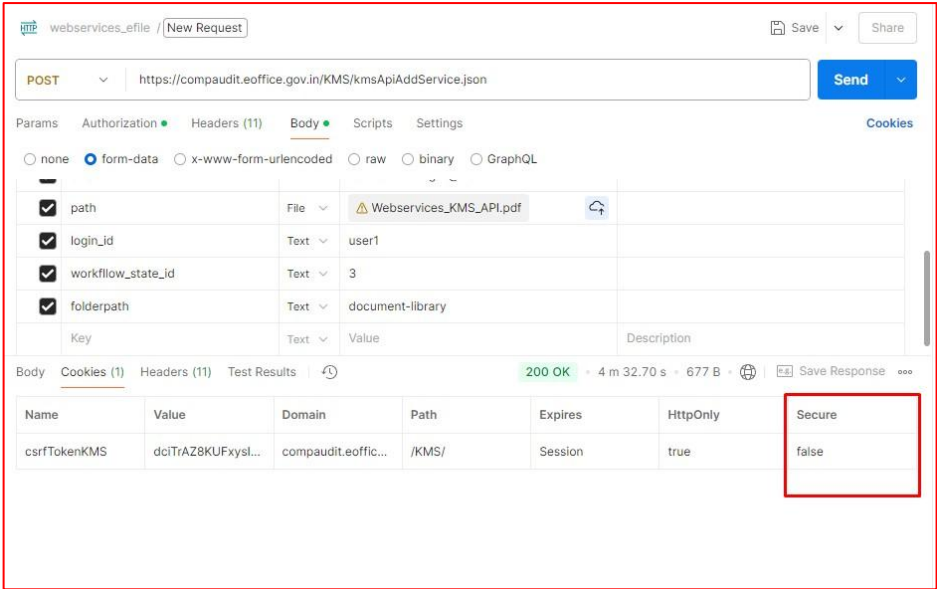
Vulnerability Title: HTTP Security Headers Not Implemented

Risk	Low
Abstract	It was observed that security headers such as X-XSS protection, Strict Transport security policy, X-ContentType-Options, Content-Type,referrer-policy were not implemented in remote application.
Impact	If security headers are not implemented in application then it may help an attacker to exploit existing vulnerabilities in application logic and results in lack of defense in depth approach to prevent security attacks.
Recommendations	It is recommended to implement security headers to provide additional layer of security in application such as X-XSS protection, Strict Transport security policy, X-ContentType-Options ,Content-Type, referrer-policy
Snapshot	
Affected Site	https://compaudit.eoffice.gov.in/KMS/kmsApiUserPermissionService.json https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json

API Security Test Report For KMS Web Services



6. Session Cookie without Secure Flag

Vulnerability Title: Session Cookie without Secure Flag	
Risk	Low
Abstract	It was observed that Session Cookie did not have Secure Flag Set.
Ease of Exploitation	Easy
Impact	This session cookie does not have the Secure flag set. When a cookie is set with the Secure flag, it instructs the browser that the cookie can only be accessed over secure SSL channels. This is an important security protection for session cookies.
Recommendations	It is recommended to set the Secure flag for this cookie.
Snapshot	
Affected Site	https://compaudit.eoffice.gov.in/KMS/kmsApiUserPermissionService.json https://compaudit.eoffice.gov.in/KMS/kmsApiViewService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDeleteService.json https://compaudit.eoffice.gov.in/KMS/kmsApiDownloadService.json https://compaudit.eoffice.gov.in/KMS/kmsApiAddNewService.json